

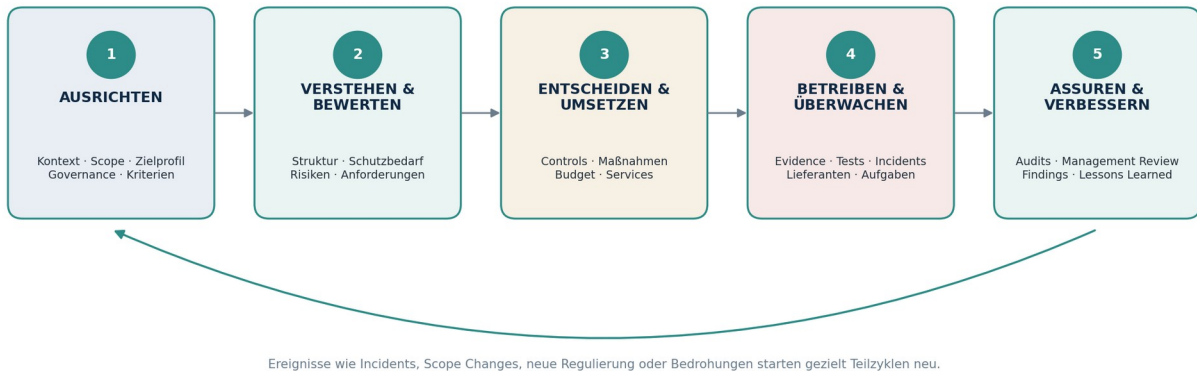
ISMS-Kernprozesse

Das fachliche Betriebsmodell

Verbindliche Prozesslogik für Aufbau, Betrieb, Überwachung und kontinuierliche Verbesserung kundenindividueller Informationssicherheits-Managementsysteme.

ISMS-Betriebsmodell: von Ziel und Kontext bis zur Verbesserung

Ein lebender Kreislauf, der durch Kalender und Ereignisse immer wieder gezielt angestoßen wird.



ARBEITSBEZEICHNUNG ISMS Managed Service Platform
VERSION 1.0 | **STATUS** Erstellt | **STAND** 21.07.2026
ABHÄNGIGKEITEN Dokument 00 bis 07

Dokumentauftrag & Verbindlichkeit

Dokument 08 ist die kanonische fachliche Prozessquelle für das ISMS-Kernprodukt. Nachfolgende Dokumente dürfen Prozesse technisch oder visuell konkretisieren, aber weder Verantwortlichkeiten noch Freigaben, Zustände oder Nachweisanforderungen stillschweigend verändern.

Zentrale Produktregel: Die Plattform führt unterschiedliche Kunden nicht zu demselben maximalen Reifegrad. Sie führt jeden Kunden nachvollziehbar zu seinem freigegebenen Zielprofil - mit angemessener Tiefe, klaren Verantwortungen und belastbarer Evidence.

Dokumentensteuerung

Merkmal	Festlegung
Dokument-ID	08
Status	Erstellt - Version 1.0
Zentrale Vorgänger	00 bis 07
Zentrale Nachfolger	09, 10, 11, 13 bis 20C
Source of Truth	08_ISMS_KERNPROZESSE_v1.0.md im Repository; PDF und DOCX sind Veröffentlichungsfassungen
Änderungsrecht	Nur über versionierten Decision Record und Abhängigkeitsprüfung

Inhalt

1 Auftrag · 2 Executive Summary · 3 Bezugsrahmen · 4 Betriebsmodell · 5 Prinzipien · 6 Prozesskatalog · 7 bis 21 Prozessdetails · 22 Managed-Service-Grenzen · 23 Workflow-Architektur · 24 Rhythmen · 25 Szenario · 26 Datenanforderungen · 27 Akzeptanz · 28 bis 31 Governance · 32 Quellen · 33 Abhängigkeiten · 34 Änderungslog

1. Dokumentauftrag und Abgrenzung

Dieses Dokument definiert die fachlichen ISMS-Kernprozesse, ihre Trigger, Rollen, Zustände, Ein- und Ausgaben, Freigaben, Automatisierungspunkte, Nachweise und Qualitätsregeln. Es konkretisiert die Produktlandkarte aus Dokument 05 und nutzt den digitalen Unternehmenszwillung aus Dokument 07 als gemeinsame Datenbasis.

Nicht festgelegt werden hier die konkrete mathematische Risiko- und Reifegradlogik (Dokument 09), das Decision Center und Simulationen (Dokument 10), technische Integrationen (Dokument 17), physische Plattformarchitektur (Dokument 18), Detailrechte und Datenschutz (Dokument 19) sowie KI- und Agentenlogik (Dokument 20A bis 20C).

Das Dokument ist kein Rechtsgutachten und ersetzt weder die lizenzpflichtigen Normtexte noch eine kundenspezifische rechtliche oder zertifizierungsbezogene Prüfung. Normen, Gesetze, BSI-Bausteine und regulatorische Anforderungen werden versioniert als Referenzobjekte eingebunden.

2. Executive Summary

Das ISMS-Kernprodukt arbeitet wie ein Betriebssystem für Informationssicherheit. Es führt Kunden und Berater nicht durch lose Menüs, sondern durch einen nachvollziehbaren Managementkreislauf:

1. Kontext, Scope und Zielzustand festlegen.
2. Geschäft, Informationen, Assets, Abhängigkeiten und Schutzbedarf verstehen.
3. Risiken und Anforderungen bewerten.
4. Controls auswählen, Verantwortungen klären und Maßnahmen planen.
5. Controls betreiben, Nachweise sammeln und Wirksamkeit prüfen.
6. Abweichungen, Incidents, Lieferantenrisiken und Veränderungen verarbeiten.
7. Managemententscheidungen vorbereiten, Audits durchführen und das System verbessern.

Jeder Prozess erzeugt strukturierte, versionierte Objekte im digitalen Zwilling. Jede kritische Aussage muss bis zu Quelle, Owner, Bewertung, Entscheidung und Nachweis zurückverfolgbar sein. Die Plattform unterstützt unterschiedliche Zielprofile: vom pragmatischen Mindestniveau über definierte Reifegrade bis zur Zertifizierungs- oder Regulierungsbereitschaft. Audit-Readiness ist damit ein möglicher Zielzustand, nicht die einzige Produktlogik.

3. Normativer und methodischer Bezugsrahmen

Die Plattform verwendet einen frameworkneutralen Prozesskern und legt Normen oder regulatorische Anforderungen als versionierte Mappings darüber. Der Kern orientiert sich insbesondere an folgenden öffentlich belegbaren Leitgedanken:

- ISO/IEC 27001 verlangt ein ISMS, das eingerichtet, umgesetzt, aufrechterhalten und fortlaufend verbessert wird und ein an die Organisation angepasstes Risikomanagement nutzt.
- ISO/IEC 27001:2022 ist der aktuelle Anforderungsstandard; Amendment 1:2024 ergänzt den Managementsystem-Kontext um Klimawandelbezug.
- BSI IT-Grundschutz verbindet Managementsystem, Strukturanalyse, Schutzbedarfsfeststellung, Modellierung, IT-Grundschutz-Check und ergänzende Risikoanalyse.
- NIS2 verlangt unter anderem Leitungsverantwortung, Risikomanagementmaßnahmen, Incident Handling, Business Continuity, Lieferkettensicherheit, Wirksamkeitsbewertung und Schulungen.
- DORA verlangt für Finanzunternehmen einen dokumentierten IKT-Risikomanagementrahmen, klare Governance, regelmäßige Überprüfung, Resilienz, Incident-, Continuity- und Drittparteiprozesse.

3.1 Produktregel für Frameworks

Ein Framework-Paket enthält mindestens Version, Gültigkeit, Quelle, Anforderungen, Kontrollziele, Mappings, Branchenhinweise, Prüflogik und Änderungsinformationen. Kunden wählen ein primäres Zielprofil und können zusätzliche Anforderungen überlagern. Ein Control kann mehrere Anforderungen bedienen; Evidence wird nicht unnötig dupliziert.

3.2 Keine versteckte Gleichsetzung

ISO 27001, BSI IT-Grundschutz, NIS2, DORA und branchenspezifische Regelwerke werden nicht als identische Checklisten behandelt. Die Plattform trennt:

- Managementsystem-Anforderungen,
- regulatorische Pflichten,
- technische und organisatorische Controls,
- Nachweis- und Meldepflichten,

- Zertifizierungs- oder Auditkriterien,
- kundenspezifische Risikoentscheidungen.

4. ISMS-Betriebsmodell

Der kanonische Kreislauf besteht aus fünf zusammenhängenden Betriebsphasen:

Phase	Leitfrage	Zentrale Ergebnisse
1. Ausrichten	Was soll geschützt und erreicht werden?	Kontext, Scope, Strategie-DNA, Ziele, Rollen, Kriterien
2. Verstehen & Bewerten	Was ist kritisch, bedroht oder unzureichend geschützt?	Strukturmodell, Schutzbedarf, Risiken, Anforderungen, Lücken
3. Entscheiden & Umsetzen	Welche Behandlung erzeugt die beste Wirkung?	Control-Set, SoA, Maßnahmen, Ausnahmen, Budget- und Serviceentscheidungen
4. Betreiben & Überwachen	Funktioniert das ISMS im Alltag?	Aufgaben, Evidence, Tests, Lieferantenreviews, Incident- und Change-Verarbeitung
5. Assuren & Verbessern	Ist das System wirksam und bleibt es angemessen?	Audits, Management Review, Findings, Verbesserungen, aktualisierte Zielroute

Der Zyklus ist nicht jährlich linear. Ereignisse wie neue Bedrohungen, Akquisitionen, Lieferantenwechsel, größere Incidents, neue Regulierung oder Auditfeststellungen starten gezielt Teilprozesse neu.

5. Übergreifende Prozessprinzipien

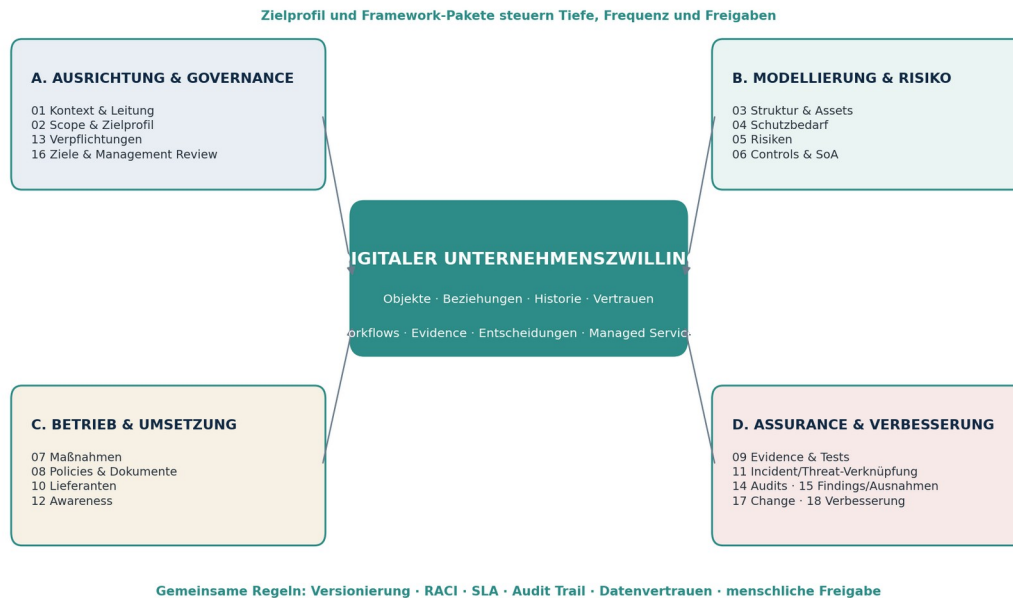
- **P01 - Zielorientierung:** Jeder Prozess bezieht sich auf das kundenspezifische Zielprofil und nicht automatisch auf maximale Reife oder Zertifizierung.
- **P02 - Geschäftsbezug:** Risiken, Controls und Maßnahmen werden mit Geschäftsprozessen, Informationen und Zielen verbunden.
- **P03 - Ein Datensatz, mehrere Nachweise:** Ein freigegebenes Artefakt kann mehrere Anforderungen bedienen, ohne unkontrollierte Kopien zu erzeugen.
- **P04 - Nachvollziehbarkeit:** Jeder Statuswechsel besitzt Actor, Zeitpunkt, Begründung, Quelle und ggf. Freigabe.
- **P05 - Trennung von Erstellung und Freigabe:** Kritische Bewertungen, Risikoakzeptanzen, Ausnahmen und Managemententscheidungen benötigen angemessene Unabhängigkeit.
- **P06 - Menschliche Verantwortung:** KI oder Regeln dürfen vorbereiten, priorisieren und erklären, aber keine rechtlich, finanziell oder risikoseitig wesentlichen Freigaben ersetzen.
- **P07 - Proportionalität:** Tiefe, Frequenz und Formalität richten sich nach Risiko, Größe, Regulierung und Zielprofil.
- **P08 - Evidenz statt Behauptung:** Control-Status und Reifegrad stützen sich auf nachvollziehbare Evidence und Tests, nicht nur Selbstauskunft.
- **P09 - Kontinuierliche Veränderung:** Scope, Assets, Bedrohungen und Pflichten werden ereignis- und kalendergesteuert neu bewertet.
- **P10 - Ausnahme mit Ablaufdatum:** Abweichungen sind befristet, begründet, kompensiert und regelmäßig zu überprüfen.
- **P11 - Wiederverwendbare Managed Services:** Standardisierte Playbooks dürfen mandantenübergreifend wiederverwendet werden; Kundendaten und Entscheidungen bleiben strikt getrennt.
- **P12 - Kein Dokumentenfriedhof:** Dokumente sind mit Prozessen, Anforderungen, Controls, Ownern und Reviews verbunden.
- **P13 - Erklärbare Priorisierung:** Dringlichkeit und Wirkung werden mit Ursachen, Abhängigkeiten und Datenvertrauen erklärt.
- **P14 - Versionierte Wahrheit:** Freigegebene Stände bleiben historisch rekonstruierbar.
- **P15 - Kernfunktion ohne generative KI:** Alle wesentlichen Prozessschritte bleiben deterministisch und manuell nutzbar.

6. Prozessarchitektur und Katalog

Die Plattform unterscheidet 18 kanonische Kernprozesse. Kunden können Prozesse deaktivieren, vereinfachen oder erweitern, solange Zielprofil und Pflichtenanforderungen dies erlauben.

Prozessarchitektur: 18 Kernprozesse, ein gemeinsamer Daten- und Entscheidungsraum

Die Prozesse sind fachlich getrennt, aber über Twin-Objekte, Workflows, Evidence und Decision Records verbunden.



ID	Prozess	Primärer Owner	Hauptergebnis
ISMS-01	Kontext, Governance und Leitungsverantwortung	Executive Sponsor / CISO	Mandat, Governance, Rollen, Leitlinien
ISMS-02	Scope- und Zielprofilmanagement	ISMS Manager	Freigegebener Scope und Zielzustand
ISMS-03	Struktur-, Asset- und Abhängigkeitsmanagement	Asset-/Process Owner	Vollständiges relevantes Strukturmodell
ISMS-04	Schutzbedarf und Kritikalität	Business / Information Owner	Bewertete Schutz- und Kritikalitätsklassen
ISMS-05	Risikomanagement	Risk Owner / ISMS Manager	Bewertete und behandelte Risikoszenarien
ISMS-06	Anforderungs-, Control- und SoA-Management	Control Owner	Begründetes Control-Set und Anwendbarkeit
ISMS-07	Maßnahmen- und Verbesserungsmanagement	Measure Owner	Umgesetzte und verifizierte Maßnahmen
ISMS-08	Policy- und Dokumentenlenkung	Policy Owner	Freigegebene, gültige und verständliche Regelwerke
ISMS-09	Evidence- und Control-Assurance	Control Tester / Reviewer	Belastbarer Wirksamkeitsnachweis
ISMS-10	Lieferanten- und Drittrisiko	Supplier Owner	Bewertete Lieferkette und Behandlungsplan
ISMS-11	Incident-, Schwachstellen- und Threat-Verknüpfung	SOC / Incident Manager	Aktualisierte Risiken, Lessons und Maßnahmen
ISMS-12	Awareness, Kompetenz und Verhalten	HR / Awareness Owner	Rollenbezogene Befähigung und Wirksamkeitsdaten
ISMS-13	Compliance- und	Compliance Owner	Aktuelle anwendbare Pflichten und

ID	Prozess	Primärer Owner	Hauptergebnis
	Verpflichtungsmanagement		Abdeckung
ISMS-14	Audit- und Assessmentmanagement	Audit Lead	Prüfprogramm, Feststellungen und Abschluss
ISMS-15	Findings, Abweichungen und Ausnahmen	Finding / Exception Owner	Befristete, kontrollierte Abweichungsbehandlung
ISMS-16	Ziele, KPIs und Management Review	Executive Sponsor	Entscheidungen, Ressourcen und Zielkorrekturen
ISMS-17	Change-, Projekt- und Scope-Impact	Change Owner	Sicherheitsbewertung relevanter Veränderungen
ISMS-18	Kontinuierliche Verbesserung und Lessons Learned	ISMS Manager	Priorisierter Verbesserungsbacklog

7. ISMS-01 - Kontext, Governance und Leitungsverantwortung

Zweck: Das ISMS erhält ein wirksames Mandat, klare Verantwortlichkeiten und eine nachvollziehbare Verbindung zur Unternehmensstrategie.

Trigger: Erstaufbau, neue Leitung, wesentliche Reorganisation, neue Regulierung, jährliche Governance-Überprüfung oder Management-Review-Beschluss.

Eingaben: Unternehmensziele, Stakeholder, regulatorischer Kontext, Risikobereitschaft, Organisationsmodell, bestehende Richtlinien, Serviceverträge.

Kernablauf:

8. relevante interne und externe Themen erfassen;
9. interessierte Parteien und Erwartungen bewerten;
10. Executive Sponsor, CISO/ISMS-Verantwortung und Stellvertretung benennen;
11. Entscheidungs-, Eskalations- und Berichtswege festlegen;
12. Informationssicherheitsleitlinie entwerfen und freigeben;
13. Ressourcen, Budgetrahmen und Managed-Service-Verantwortung festlegen;
14. Governance-Kalender aktivieren.

Ausgaben: Governance Charter, Rollenmatrix, Leitlinie, RACI, Eskalationsmodell, Reviewkalender, dokumentierte Managementfreigabe.

Produktfunktion: Geführter Governance-Setup, Verantwortlichkeitsgraph, offene Managemententscheidungen, automatische Review-Erinnerungen und lückenloser Decision Record.

Kontrollen: Kein aktiver Zielbetrieb ohne Sponsor; kritische Rollen ohne Owner erzeugen Blocker; Delegation verändert nicht die dokumentierte Letztverantwortung.

8. ISMS-02 - Scope- und Zielprofilmanagement

Zweck: Der Kunde definiert, was das ISMS umfasst, warum es umfasst ist und welches Sicherheits- bzw. Compliance-Ziel erreicht werden soll.

Scope-Objekte: Rechtseinheiten, Standorte, Produkte, Services, Prozesse, Informationen, Systeme, Lieferanten, organisatorische Grenzen und begründete Ausschlüsse.

Zielprofile können kombinieren:

- pragmatisches Basisniveau,
- definierter Reifegrad,
- ISO/IEC-27001-Zertifizierungsbereitschaft,
- IT-Grundschutz-Vorgehensweise oder Zertifizierungsziel,
- NIS2-/DORA-/branchenspezifische Pflichterfüllung,
- resilienz- oder risikobasierte Unternehmensziele,

- individuell priorisierte Managed Services.

Kernablauf: Scope-Vorschlag -> Abhängigkeitsprüfung -> Ausschlussbegründung -> Zielprofil und Zieltermin -> Ressourcen-/Budgetannahmen -> Stakeholderreview -> Freigabe -> Baseline.

Pflichtregeln: Ausschlüsse dürfen keine wesentlichen Abhängigkeiten verdecken. Scope-Änderungen lösen Impact-Analyse auf Risiken, Controls, Evidence, Audits, Services und Reporting aus. Die Plattform speichert Ist-Scope, Ziel-Scope und Übergangsphase getrennt.

Ausgaben: Scope Statement, Grenz- und Schnittstellenliste, Zielprofil, Roadmap-Grundlage, Scope-Version, offene Datenlücken.

9. ISMS-03 und ISMS-04 - Struktur, Assets, Schutzbedarf und Kritikalität

9.1 Strukturanalyse

Die Plattform bildet zuerst den Geschäftskontext, dann die technischen und organisatorischen Träger ab. Minimum sind kritische Geschäftsprozesse, Information Assets, Anwendungen/Services, relevante Infrastruktur, Standorte, Lieferanten und Owner.

Erfassungswege: geführte Workshops, Dateimport, CMDB-/Cloud-/Identity-Konnektoren, bestehende Verzeichnisse, automatische Vorschläge und manuelle Ergänzung.

Qualitätsregeln: Jedes kritische Objekt benötigt Owner, Scope, Quelle, Aktualität und mindestens eine relevante Beziehung. Massenimporte bleiben als „beobachtet“ markiert, bis Matching und fachliche Bestätigung erfolgen.

9.2 Schutzbedarf und Business Impact

Schutzbedarf wird nicht nur technisch vergeben. Die Plattform unterstützt je Zielprofil Vertraulichkeit, Integrität, Verfügbarkeit sowie optionale Dimensionen wie Authentizität, Nachvollziehbarkeit, Sicherheit, Privatsphäre und Resilienz.

Bewertungen nutzen nachvollziehbare Schadensszenarien, Zeitabhängigkeit, regulatorische Folgen, finanzielle Auswirkungen, Personenbezug, Lieferfähigkeit und Reputation. Vererbung entlang von Abhängigkeiten ist konfigurierbar und muss erklärt werden; sie darf nicht blind jeden Höchstwert übertragen.

Ausgaben: Strukturmodell, Kritikalitätsstufen, Schutzbedarfsbegründung, Datenlücken, Owner-Aufgaben, priorisierte Modellierungsbereiche.

10. ISMS-05 - Risikomanagement

Zweck: Risiken werden als konkrete, geschäftsbezogene Szenarien identifiziert, bewertet, behandelt, überwacht und geschlossen oder akzeptiert.

10.1 Risikoszenario

Ein Szenario verbindet mindestens Bedrohung oder Ursache, Schwachstelle bzw. unzureichende Bedingung, betroffene Objekte, Ereignis, geschäftliche Auswirkungen, bestehende Controls, Risiko-Owner, Bewertungszeitpunkt und Quellen.

10.2 Kanonischer Ablauf

15. Risiko-Signal oder Workshop-Erkenntnis erfassen.
16. Dubletten und verwandte Szenarien prüfen.
17. Scope, Assets, Prozesse und Ziele verknüpfen.
18. inhärentes Risiko bewerten.
19. bestehende Controls und deren Wirksamkeit berücksichtigen.
20. Restrisiko bestimmen.
21. Behandlungsoption wählen: vermeiden, reduzieren, übertragen/teilen, akzeptieren oder bewusst beobachten.
22. Maßnahmen, Budget, Service und Zieltermin planen.
23. Risikoentscheidung freigeben.
24. Monitoring, Reassessment und Closure durchführen.

10.3 Freigaben

Risikoakzeptanz benötigt Risiko-Owner, Begründung, Gültigkeitsende, kompensierende Controls und Schwellenwertlogik. Oberhalb definierter Toleranzen eskaliert die Plattform an die vorgesehene Leitungsebene. Abgelaufene Akzeptanzen werden nicht still verlängert.

10.4 Prozesszustände

Draft -> Identified -> Under Assessment -> Assessed -> Treatment Proposed -> Decision Pending -> Accepted / In Treatment / Monitored -> Residual Review -> Closed / Reopened.

Die genaue Bewertungsmethodik, Aggregation, dynamische Bedrohungsanpassung und Simulation werden in Dokument 09 und 10 definiert.

11. ISMS-06 - Anforderungen, Controls und Statement of Applicability

Zweck: Aus Zielprofil, Pflichten und Risiken entsteht ein begründetes, prüfbares und betreibbares Control-Set.

11.1 Trennung der Ebenen

- **Requirement:** externe oder interne Anforderung.
- **Control Objective:** beabsichtigte Schutzwirkung.
- **Control:** zu betreibende Regel oder Fähigkeit.
- **Control Implementation:** konkrete Umsetzung beim Kunden.
- **Control Test:** Prüfung von Design und Wirksamkeit.
- **Evidence:** belastbarer Nachweis.

11.2 Auswahl und Mapping

Controls können aus Framework-Bibliotheken, Branchenpaketen, Kundenstandards oder Risikobehandlungen stammen. Mappings werden versioniert und zeigen, ob sie vollständig, teilweise oder nur indirekt abdecken. Ein Mapping allein beweist keine Wirksamkeit.

11.3 Statement of Applicability

Für ISO-orientierte Zielprofile verwaltet die Plattform eine versionierte Anwendbarkeitserklärung mit Anwendbarkeit, Begründung, Implementierungsstatus, Owner, Referenzen, Abweichungen und Evidence. Für andere Frameworks wird dasselbe Prinzip als Control Applicability Register verwendet.

11.4 Control-Lebenszyklus

Proposed -> Applicable / Not Applicable -> Designed -> Implemented -> Operating -> Tested -> Effective / Partially Effective / Ineffective -> Remediation -> Retested -> Retired.

Kontrollregel: „Implemented“ ist kein Synonym für „effective“. Managementberichte müssen Implementierung, Betrieb und Wirksamkeit unterscheiden.

12. ISMS-07 und ISMS-15 - Maßnahmen, Findings, Abweichungen und Ausnahmen

12.1 Maßnahmenmanagement

Eine Maßnahme besitzt Problembezug, erwartete Wirkung, verknüpfte Risiken/Controls/Findings, Owner, Aufwand, Kosten, Zieltermin, Abhängigkeiten, Akzeptanzkriterien und Verifikationsmethode.

Priorisiert wird nicht nur nach Fälligkeit, sondern nach Risikowirkung, Zielbeitrag, regulatorischer Dringlichkeit, Aufwand, Abhängigkeiten, verfügbaren Skills und Datenvertrauen.

Zustände: Proposed -> Triaged -> Approved -> Planned -> In Progress -> Blocked -> Ready for Verification -> Verified -> Closed / Reopened / Cancelled.

12.2 Findings

Findings entstehen aus Audits, Assessments, Tests, Incidents, Lieferantenreviews oder Datenqualitätsprüfungen. Sie besitzen Schweregrad, objektive Evidence, Kriterium, Abweichungsbeschreibung, Root Cause, Korrektur, Korrekturmaßnahme und Wirksamkeitsprüfung.

12.3 Ausnahmen

Eine Ausnahme benötigt betroffene Regel, Scope, Risiko, Geschäftsbegründung, kompensierende Controls, Owner, Genehmiger, Start- und Enddatum, Reviewfrequenz und Exit-Plan. Ausnahmen erscheinen in Management Review und Auditpaketen.

13. ISMS-08 - Policy- und Dokumentenlenkung

Zweck: Regelwerke sind gültig, verständlich, auffindbar, versioniert und mit Umsetzung sowie Nachweisen verbunden.

13.1 Dokumenttypen

Leitlinien, Policies, Standards, Verfahren, Arbeitsanweisungen, Konzepte, Pläne, Register, Vorlagen und externe Dokumente.

13.2 Lebenszyklus

Draft -> In Review -> Approved -> Published -> Acknowledgement Pending -> Active -> Review Due -> Superseded -> Archived.

13.3 Pflichtmetadaten

Owner, Approver, Zielgruppe, Geltungsbereich, Klassifikation, Version, Gültigkeit, Reviewdatum, verknüpfte Anforderungen/Controls/Prozesse, Sprachversionen und Änderungsgrund.

13.4 Nutzererlebnis

Die Plattform zeigt nicht nur Dateien, sondern beantwortet: Welche Regel gilt für mich? Was hat sich geändert? Welche Umsetzung wird erwartet? Welche Controls und Prozesse hängen davon ab? Eine Richtlinie kann als lesbare Webansicht, freigegebene Datei und zitierbares Reportartefakt bereitstehen.

14. ISMS-09 - Evidence- und Control-Assurance

Zweck: Die Plattform beweist nicht nur, dass ein Control beschrieben ist, sondern ob es angemessen gestaltet und wirksam betrieben wird.

14.1 Evidence-Arten

Konfigurationen, Screenshots, Logs, Tickets, Protokolle, Verträge, Schulungsnachweise, Testresultate, Interviews, Stichproben, Begehungen, Systemabfragen und freigegebene Erklärungen.

14.2 Evidence-Vertrag

Evidence besitzt Quelle, Erfassungszeit, fachliche Gültigkeit, Scope, Owner, Klassifikation, Integritätsschutz, Reviewstatus, Ablauf/Erneuerung, verknüpfte Controls und Anforderungen. Automatisch gesammelte Evidence wird als solche gekennzeichnet.

14.3 Assurance-Ablauf

Testziel -> Prüfschritt -> Stichprobe -> Evidence -> Ergebnis -> Reviewer -> Finding bei Abweichung -> Remediation -> Retest. Design Effectiveness und Operating Effectiveness werden getrennt bewertet.

14.4 Wiederverwendung

Evidence kann mehrere Anforderungen abdecken, wenn Scope, Zeitraum und Aussage passen. Die Plattform warnt vor überdehnter Wiederverwendung und veralteten Nachweisen.

15. ISMS-10 - Lieferanten- und Drittrisiko

Zweck: Externe Abhängigkeiten werden nach Kritikalität, Datenzugriff, Konzentration, Subunternehmern, Resilienz und Control-Reife gesteuert.

Ablauf: Intake -> Kritikalitätsklassifikation -> Due Diligence -> Vertrags- und Control-Anforderungen -> Entscheidung -> Onboarding -> laufendes Monitoring -> Ereignis-/Reviewprozess -> Renewal oder Exit.

Bewertungsquellen: Fragebogen, Zertifikate, Auditberichte, Vertragsdaten, Security Ratings, Incident-Historie, technische Integrationen, Exit- und Kontinuitätspläne.

Besonderheiten: Kritische Lieferanten benötigen Owner, Servicebezug, Datenflüsse, Subdienstleister, Recovery-Annahmen und Exit-Strategie. Selbstauskunft allein gilt nicht als ausreichende Assurance.

Managed-Service-Potenzial: standardisierte Triage, Nachforderung fehlender Nachweise, Reviewkalender, Vertragskontroll-Check, Portfoliobenchmark und Eskalationsvorbereitung.

16. ISMS-11 - Incident-, Schwachstellen- und Threat-Verknüpfung

Die Plattform ersetzt weder SIEM, SOC, Incident-Response-Plattform noch Schwachstellenscanner. Sie übersetzt deren relevante Signale in Governance, Risiko, Controls, Entscheidungen und Verbesserungen.

16.1 Eingangssignale

Security Incident, Datenschutzvorfall, Schwachstelle, Threat Bulletin, Kontrollausfall, Business Change, technisches Finding oder externe Warnung.

16.2 Verarbeitung

Signal klassifizieren -> Twin-Objekte matchen -> Geschäfts- und Scope-Betroffenheit bestimmen -> bestehende Risiken/Controls prüfen -> neue oder geänderte Bewertung vorschlagen -> notwendige Entscheidung, Maßnahme, Meldung oder Serviceaktivität auslösen -> Lessons Learned übernehmen.

16.3 Kontrollpunkte

- Keine automatische Hochstufung ohne dokumentierte Regel und nachvollziehbare Betroffenheit.

- Meldepflichten und Fristen sind versionierte regulatorische Workflows.
- Operative Incident-Daten werden nur im für Governance und Nachweis erforderlichen Umfang übernommen.
- Nach Abschluss werden Root Cause, Control Failure und Verbesserungsbedarf in das ISMS zurückgeführt.

17. ISMS-12 - Awareness, Kompetenz und Sicherheitsverhalten

Zweck: Menschen erhalten die für ihre Rolle erforderliche Kompetenz; Wirksamkeit wird über Teilnahme hinaus bewertet.

Elemente: Rollen- und Risikoprofile, Onboarding, Basisschulung, zielgruppenspezifische Lernpfade, Phishing-/Verhaltensübungen, Führungskräfte-Training, Nachweise, Ausnahmen und Wiederholungen.

Wirksamkeitsmaße: Wissenszuwachs, Fehlerquote, Meldeverhalten, Wiederholungsrisiken, Abschluss kritischer Trainings und beobachtete Verhaltensindikatoren. Einzelpersonen dürfen nicht unangemessen überwacht oder öffentlich gerankt werden.

Prozess: Kompetenzbedarf -> Lernmaßnahme -> Einladung -> Durchführung -> Nachweis -> Wirksamkeitsprüfung -> Nachsteuerung.

18. ISMS-13 - Compliance- und Verpflichtungsmanagement

Zweck: Anwendbare gesetzliche, regulatorische, vertragliche und interne Verpflichtungen werden erkannt, versioniert, verantwortet und mit Controls sowie Evidence verbunden.

Ablauf: Quelle aufnehmen -> Anwendbarkeit prüfen -> Verpflichtung interpretieren -> Owner zuweisen -> Control-Mapping -> Gap bewerten -> Maßnahme -> Nachweis -> regelmäßige Rechts-/Versionsprüfung.

Die Plattform unterscheidet juristische Quelle, fachliche Interpretation, interne Anforderung und technische Umsetzung. Juristische Interpretation benötigt menschliche Freigabe und wird nicht als automatische Rechtsberatung dargestellt.

Änderungen an einem Regelwerk erzeugen Delta-Analyse statt vollständiger Neubewertung, soweit das Mapping belastbar ist.

19. ISMS-14 - Audit- und Assessmentmanagement

19.1 Auditarten

Interne Audits, Zertifizierungs-/Überwachungsaudits, Kunden- oder Lieferantenaudits, regulatorische Prüfungen, Control Self Assessments, Reifegradassessments und thematische Reviews.

19.2 Auditprozess

Programm -> Auditauftrag -> Scope/Kriterien -> Planung -> Ressourcen/Reise -> Evidence Request List -> Durchführung remote/vor Ort -> Feststellungen -> Abstimmung -> Bericht -> Maßnahmen -> Verifikation -> Abschluss.

19.3 Plattformfunktionen

- risikobasiertes Auditprogramm,
- Auditor-Unabhängigkeitsprüfung,
- Interview- und Stichprobenplanung,
- sichere Evidence-Räume,
- Echtzeitstatus der Anforderungen,
- Reisezeit und Vor-Ort-Termine,
- automatische Berichtsentwürfe,
- Findings- und Follow-up-Workflow,
- Stichtagssnapshot des geprüften ISMS.

Audit-Readiness wird als Verhältnis aus definierter Zielabdeckung, Evidence-Aktualität, Control-Wirksamkeit, offenen Findings, Scope-Stabilität und Datenvertrauen dargestellt. Die genaue Formel folgt in Dokument 09 und 10.

20. ISMS-16 - Ziele, KPIs und Management Review

Zweck: Die Leitung bewertet Eignung, Angemessenheit und Wirksamkeit des ISMS und trifft nachvollziehbare Entscheidungen zu Risiken, Ressourcen, Zielen und Verbesserungen.

20.1 Eingaben

Ziel- und KPI-Trends, Risikoentwicklung, Control-Assurance, Findings, Auditergebnisse, Incidents, Lieferantenlage, Ressourcen und Kapazitäten, Stakeholderänderungen, Zielprofilfortschritt, Managed-Service-Performance und offene Ausnahmen.

20.2 Ablauf

Review-Paket erzeugen -> Datenqualität bestätigen -> Voranalyse durch ISMS Manager/Berater -> Managementsitzung -> Entscheidungen und Maßnahmen protokollieren -> Verantwortungen und Termine setzen -> Kommunikation -> Follow-up.

20.3 Ergebnis

Decision Records, geänderte Ziele, freigegebene Risiken, Budget- oder Serviceentscheidungen, priorisierte Verbesserungen, Governance-Anpassungen und dokumentierte Schlussfolgerung.

Die Executive Experience zeigt wenige entscheidungsrelevante Aussagen; Detaildaten bleiben drill-down-fähig.

21. ISMS-17 und ISMS-18 - Change Impact und kontinuierliche Verbesserung

21.1 Change Impact

Relevante Changes wie neue Produkte, Cloudmigrationen, M&A, Standortwechsel, neue Lieferanten, Architekturänderungen oder regulatorische Änderungen werden vor Freigabe sicherheitsseitig bewertet.

Ablauf: Change Signal -> Kritikalität -> betroffene Twin-Objekte -> Scope-/Risiko-/Control-/Evidence-Impact -> erforderliche Aufgaben und Freigaben -> Umsetzung -> Post-Implementation Review.

21.2 Kontinuierliche Verbesserung

Verbesserungen stammen aus Findings, Incidents, Nutzerfeedback, Kennzahlen, Audits, Management Reviews, Datenqualitätsproblemen, Bedrohungsänderungen und Beratungs-Learnings.

Der Verbesserungsbacklog trennt Korrektur, Korrekturmaßnahme, Prävention, Effizienzverbesserung und Produkt-/Serviceidee. Jede Verbesserung benötigt erwarteten Nutzen, Priorität, Owner und Wirksamkeitskriterium.

22. Rollen, Verantwortungen und Managed-Service-Grenzen

Aktivität	Kunde bleibt verantwortlich	Service Provider kann übernehmen	Menschliche Freigabe zwingend
Scope und Zielprofil	Geschäftsentscheidung und Vollständigkeit	Vorbereitung, Workshops, Impactanalyse	Executive Sponsor / benannte Leitung
Risikoanalyse	Risikokontext und Risikoeigentum	Moderation, Datenaufbereitung, Vorschläge	Risk Owner gemäß Schwellenwert
Control-Betrieb	fachliche/operative Verantwortlichkeit	ausgewählte operative Kontrollen und Monitoring	bei wesentlichen Designänderungen
Evidence	Wahrheit und Zugriffsberechtigung	Sammlung, Strukturierung, Qualitätsprüfung	bei sensibler Veröffentlichung/Auditfreigabe
Risikoakzeptanz	nicht delegierbare Entscheidung	Entscheidungsvorlage und Alternativen	zuständige Managementebene
Policy	Geltung und Kommunikation	Entwurf, Mapping, Reviewsteuerung	Policy Owner / Approver
Audit	Zugang, Richtigkeit, Managementreaktion	Planung, Vorbereitung, Koordination	Auditbericht und Managementreaktion
Ausnahme	Geschäftsbegründung und Restrisiko	Dokumentation, Fristenkontrolle, Kompensationsvorschläge	definierter Approver
Management Review	Leitung bewertet und entscheidet	Reporting, Analyse, Moderation	Leitungsorgan

Managed Services werden als konkrete Verantwortungs- und Ergebnisbausteine modelliert. Jeder Service nennt Scope, Eingaben, Tätigkeiten, Deliverables, SLA, RACI, Freigaben, Ausschlüsse, Qualitätskennzahlen und Exit-Regeln.

23. Workflow- und Zustandsarchitektur

23.1 Gemeinsamer Workflow-Vertrag

Jeder Workflow besitzt Trigger, fachlichen Zweck, Objektcontext, Verantwortliche, SLA, Schritte, Entscheidungsregeln, Eskalation, Evidence, Ergebnis, Version und Audit Trail.

23.2 Universelle Zustandslogik

Draft -> Ready -> In Review -> Approved -> Active -> Change Pending -> Superseded / Closed dient als Basismuster. Fachobjekte verwenden spezialisierte Zustände, bleiben aber auf dieses Muster abbildbar.

23.3 Blocker und Eskalation

Blocker unterscheiden fehlende Daten, fehlende Entscheidung, fehlende Berechtigung, externe Abhängigkeit, Kapazitätsproblem und technisches Hindernis. Eskalationen nennen Konsequenz und nächste sinnvolle Option; sie bestehen nicht nur aus Erinnerungsmails.

23.4 Automatisierungsstufen

25. Erinnerung und Terminierung.
26. Regelbasierte Aufgabenerzeugung.
27. Datenimport und Statusvorschlag.
28. deterministische Berechnung und Routing.

29. KI-gestützte Zusammenfassung oder Empfehlung.

30. menschlich freigegebene Ausführung.

Kritische Prozesse müssen bei Ausfall externer KI weiterhin auf Stufe 1 bis 4 funktionieren.

24. Betriebsrhythmen und Kalender

Rhythmus	Typische Aktivitäten
Ereignisgesteuert	Incident, kritische Schwachstelle, neue Regulierung, Scope Change, Lieferantenausfall
Täglich	Morning Mission, kritische Aufgaben, SLA-Verstöße, neue Signals, Datenqualitätswarnungen
Wöchentlich	Beraterportfolio, Maßnahmenreview, Finding-Triage, Service Delivery Sync
Monatlich	KPI-/Risikotrend, Control Monitoring, Servicebericht, Lieferantenänderungen
Quartalsweise	Zielroutenreview, ausgewählte Control Tests, Executive Update, Ressourcenplanung
Halbjährlich	Policy-/Scope-/Risikomodellreview je Kritikalität, Awareness-Wirksamkeit
Jährlich	Management Review, Auditprogramm, Governance, Zielprofil, umfassende Risikobewertung
Mehrfährig / nach Anlass	Zertifizierung, Strategieänderung, großes Resilience Testing, Re-Design des ISMS

Frequenzen sind pro Zielprofil und Kritikalität konfigurierbar. „Jährlich“ ist kein Freibrief, relevante Veränderungen bis zum Termin zu ignorieren.

25. Durchgängiges End-to-End-Szenario

Ausgangslage: Ein Produktionskunde plant eine Cloudmigration. Gleichzeitig veröffentlicht ein Security-Tool eine kritische Schwachstelle in einer betroffenen Identitätskomponente.

31. Der Change-Prozess importiert das Migrationsvorhaben und verknüpft es mit Prozessen, Informationen und Zielsystemen.
32. Das Threat-/Vulnerability-Signal wird den betroffenen Assets zugeordnet; Datenvertrauen und Quelle sind sichtbar.
33. Die Plattform identifiziert einen Wirkungspfad zu einem kritischen Produktionsprozess.
34. Ein bestehendes Risiko wird zur Neubewertung vorgeschlagen; ein neues Szenario bleibt Entwurf, bis es fachlich bestätigt ist.
35. Bestehende Controls werden auf Design, Betrieb und Evidence-Aktualität geprüft.
36. Drei Behandlungsoptionen werden vorbereitet: technische Härtung, Migrationsverschiebung oder temporärer Managed Monitoring Service.
37. Das Decision Center zeigt Kosten, Zeit, Risikowirkung, Abhängigkeiten und Vertrauen je Option.
38. Der Risk Owner entscheidet; bei Toleranzüberschreitung genehmigt die Leitung.
39. Maßnahmen, Serviceaktivitäten und Evidence-Anforderungen werden automatisch erzeugt.
40. Nach Umsetzung prüft ein unabhängiger Reviewer die Wirksamkeit.
41. Der Change wird freigegeben, das Restrisiko aktualisiert und der Managementbericht angepasst.
42. Lessons Learned fließen in Workflow-Vorlage, Lieferantenanforderung und künftige Migrationsprojekte ein.

Dieses Szenario demonstriert, dass die Plattform keine isolierten Checklisten betreibt, sondern Daten, Prozesse, Entscheidungen, Services und Assurance verbindet.

26. Daten-, Reporting- und Schnittstellenanforderungen

- Jeder Kernprozess liest und schreibt kanonische Twin-Objekte aus Dokument 07.
- Prozessstatus und fachlicher Objektstatus werden getrennt gespeichert.
- Reports verwenden freigegebene Snapshots und nennen Stichtag, Scope, Quellen und Datenlücken.

- Imports erzeugen keine stillen Freigaben; sie liefern Beobachtungen und Vorschläge.
- Alle wesentlichen Entscheidungen sind als Decision Record exportierbar.
- Workflow-Events können über API/Eventbus an Ticketing, SIEM, CMDB, HR, GRC oder Collaboration-Systeme übergeben werden.
- Mandanten müssen ihre Daten, Historie, Evidence und offenen Workflows portabel exportieren können.
- Externe IDs und Quellsystemzustände bleiben nachvollziehbar.
- Regulatorische Fristen werden mit Zeitzone, Startsignal, Pausenregeln und Eskalation modelliert.

27. Globale Akzeptanzkriterien

- Alle 18 Kernprozesse besitzen Trigger, Owner, Eingaben, Ausgaben, Status, Freigaben, Evidence und Audit Trail.
- Zielprofile können Mindestniveau, Reifegrad, Zertifizierungs- und Regulierungsziele kombinieren.
- Audit-Readiness ist konfigurierbar und kein erzwungenes Universalziel.
- Scope-Änderungen propagieren nachvollziehbar auf Risiken, Controls, Evidence, Audits, Services und Reporting.
- Risk, Control, Measure, Finding, Policy, Evidence, Exception und Audit besitzen klar getrennte Lebenszyklen.
- „Implementiert“ und „wirksam“ sind in Datenmodell, UI und Reporting getrennt.
- Risiken können nicht ohne Owner, Begründung und Gültigkeit akzeptiert werden.
- Ausnahmen besitzen Ablaufdatum, kompensierende Controls und Exit-Plan.
- Evidence enthält Quelle, Gültigkeit, Scope, Integrität und Reviewstatus.
- Audits können remote, vor Ort oder hybrid geplant werden; Reise und Kapazität werden berücksichtigt.
- Management Reviews erzeugen versionierte Entscheidungen und Follow-up-Aufgaben.
- Incidents und Schwachstellen können Risiken und Controls aktualisieren, ohne operative Security-Tools zu ersetzen.
- Lieferantenprozesse berücksichtigen Kritikalität, Subdienstleister, Konzentration, Continuity und Exit.
- Pflicht- und Framework-Mappings sind versioniert und beweisen nicht automatisch Control-Wirksamkeit.
- Kritische Workflows funktionieren ohne generative KI.
- Jeder sichtbare Score oder Status kann bis zu Daten, Regel, Owner und Freigabe erklärt werden.
- Managed Services besitzen RACI, SLA, Deliverables, Qualitätsmaß und Exit-Regel.
- Synthetische Demodatensätze bilden mindestens einen vollständigen ISMS-Jahreszyklus sowie mehrere ereignisgesteuerte Abweichungen ab.

28. Verbindliche Entscheidungen

- **08-D01:** Die Plattform besitzt einen frameworkneutralen ISMS-Prozesskern; Normen und Regulierungen werden als versionierte Referenz- und Mappingpakete überlagert.
- **08-D02:** Das kundenspezifische Zielprofil steuert Prozessumfang, Tiefe und Priorisierung; maximale Reife oder Audit-Readiness sind nicht automatisch Ziel.
- **08-D03:** Die 18 in diesem Dokument definierten Prozesse bilden den kanonischen fachlichen Prozesskatalog.
- **08-D04:** Jeder Kernprozess verwendet Objekte und Beziehungen des digitalen Zwillings aus Dokument 07.
- **08-D05:** Eingelesene Daten und automatisch erzeugte Vorschläge gelten nicht als fachlich freigegeben, solange ein erforderlicher Owner oder Reviewer nicht bestätigt hat.
- **08-D06:** Risikoakzeptanzen, wesentliche Ausnahmen, Scopefreigaben und Management-Review-Entscheidungen bleiben menschliche Verantwortungsakte.
- **08-D07:** Implementierung, operativer Betrieb und Wirksamkeit eines Controls werden getrennt bewertet.
- **08-D08:** Evidence ist versioniert, quellenbezogen, zeitlich gültig und mit Scope sowie Aussagezweck verknüpft.
- **08-D09:** Policies und Dokumente sind Prozessobjekte mit Owner, Gültigkeit, Review, Zielgruppe und Verknüpfungen; keine unstrukturierte Dateiablage.
- **08-D10:** Ausnahmen sind befristet und benötigen Risiko, kompensierende Controls, Genehmiger und Exit-Plan.
- **08-D11:** Incidents, Threats und Schwachstellen werden in das ISMS übersetzt; die Plattform ersetzt keine operativen Detection- oder Response-Systeme.
- **08-D12:** Audit-, Assessment- und Kontrollprüfungen verwenden freigegebene Stichtagssnapshots und erhalten ihre eigene Evidence- und Finding-Historie.
- **08-D13:** Managed Services werden als standardisierte, aber kundenspezifisch konfigurierte Prozessverantwortungen mit RACI, SLA, Deliverables und Exit-Regeln modelliert.
- **08-D14:** Kritische Kernworkflows müssen ohne generative KI vollständig durchführbar sein.
- **08-D15:** Prozessautomatisierung wird stufenweise eingeführt und darf keine unsichtbaren Risiko- oder Compliancefreigaben erzeugen.
- **08-D16:** Alle regulatorischen und Framework-Inhalte tragen Version, Quelle, Gültigkeit und Änderungsinformation.
- **08-D17:** Cross-Framework-Mappings dienen Wiederverwendung und Orientierung, sind aber kein automatischer Konformitätsbeweis.
- **08-D18:** Jeder Managementstatus muss Ursachen, Datenvertrauen und nächste Entscheidung erklären können.
- **08-D19:** Reisezeit, Vor-Ort-Audits, Kapazität und externe Abhängigkeiten sind reguläre Prozessparameter und keine nachträgliche Kalendernotiz.
- **08-D20:** Prozessstände und fachliche Objektstände werden technisch und fachlich getrennt behandelt.

29. Begründete Annahmen

- **08-A01:** Kunden besitzen sehr unterschiedliche Reife, Datenqualität und Prozessformalität; geführte und Expertenmodi sind erforderlich.

- **08-A02:** Viele Kunden starten mit Excel-, Word-, SharePoint-, Ticketing- und GRC-Beständen, die schrittweise migriert werden.
- **08-A03:** Ein gemeinsamer Prozesskern kann ISO-, BSI- und regulatorische Ziele abdecken, wenn Unterschiede explizit bleiben.
- **08-A04:** Nicht jeder Control-Test kann automatisiert werden; Interviews, Stichproben und Vor-Ort-Prüfungen bleiben notwendig.
- **08-A05:** Ein Teil der Managed Services wird wiederkehrend standardisierbar, während Risikoakzeptanz und strategische Entscheidungen kundenspezifisch bleiben.
- **08-A06:** Framework-Inhalte und Mappings benötigen lizenz-, urheber- und versionsgerechte Beschaffung.
- **08-A07:** Nationale NIS2-Umsetzung, Aufsichtspraxis und branchenspezifische Anforderungen können zusätzliche Pakete erfordern.
- **08-A08:** Fachliche Rollen können bei kleineren Kunden von einer Person gebündelt werden; die Plattform muss dennoch Funktionstrennung und Interessenkonflikte sichtbar machen.
- **08-A09:** Automatische Evidence-Erfassung reduziert Aufwand, erhöht aber Anforderungen an Herkunft, Integrität und Scope-Matching.
- **08-A10:** Der Prototyp arbeitet mit synthetischen Daten und simulierten Integrationen, bildet aber vollständige reale Prozessketten ab.
- **08-A11:** Ein Task-/Workflow-Modul wird integriert, ersetzt jedoch nicht zwingend das kundenseitige Enterprise-Ticketing.
- **08-A12:** Management-KPIs und Risikoscores werden je Zielprofil konfigurierbar sein und benötigen Schwellenwert-Governance.

30. Offene Fragen

- **08-O01:** Welche Teilmenge der 18 Prozesse muss im ersten funktionsfähigen Build vollständig interaktiv sein?
- **08-O02:** Welche Framework-Pakete werden für die erste Demo rechtlich und inhaltlich vollständig verfügbar gemacht?
- **08-O03:** Welche Risiko- und Schutzbedarfsmodelle werden als Standard ausgeliefert und welche nur als Vorlage?
- **08-O04:** Welche Freigabeschwellen gelten in der Demo für Risikoakzeptanz, Ausnahme und Scope Change?
- **08-O05:** Wie granular wird die Statement-of-Applicability-Funktion im ersten Build umgesetzt?
- **08-O06:** Welche Evidence-Typen werden echt importiert und welche synthetisch simuliert?
- **08-O07:** Welche Integrationen sind bidirektional und welches System bleibt System of Record je Objektart?
- **08-O08:** Wie werden regulatorische Meldefristen und nationale Varianten produktseitig gepflegt?
- **08-O09:** Welche Unabhängigkeitsregeln gelten für Control Tester, interne Auditoren und Managed-Service-Berater?
- **08-O10:** Welche Audit- und Zertifizierungsbegriffe dürfen im Produktmarketing verwendet werden, ohne unzulässige Konformitätsversprechen?
- **08-O11:** Welche Serviceaktivitäten darf der Provider automatisiert starten und welche brauchen Kundenfreigabe?
- **08-O12:** Wie werden große Mengen technischer Findings aggregiert, ohne das ISMS mit Scannerrauschen zu überlasten?
- **08-O13:** Welche Prozesse benötigen mobile oder offline-fähige Erfassung für Begehungen und Vor-Ort-Audits?
- **08-O14:** Wie wird Prozesskonfiguration versioniert und zwischen Mandanten-Templates sowie kundenspezifischen Varianten getrennt?
- **08-O15:** Welche Daten müssen bei Offboarding in welchem portablen Format exportierbar sein?

31. Ideenparkplatz

- **ISMS Autopilot Board:** Zeigt alle wiederkehrenden Zyklen, die gesund laufen, und nur echte Abweichungen, die menschliche Aufmerksamkeit brauchen.
- **Control Passport:** Portable 360-Grad-Karte eines Controls mit Zweck, Implementierung, Evidence, Tests, Risiken und Framework-Abdeckung.
- **Evidence Freshness Radar:** Erkennt vor Audit oder Management Review veraltete, widersprüchliche oder zu schwach scoped Nachweise.
- **Exception Burn-down:** Visualisiert befristete Ausnahmen, Restrisiko und Exit-Fortschritt statt bloßer Ausnahmeanzahl.
- **Change Security Gate:** Wiederverwendbares Sicherheits-Gate für Projekte, M&A, Cloudmigration und neue Lieferanten.
- **Audit Day Mode:** Reduzierte Oberfläche für Interviewplan, Evidence, Live-Findings, offene Fragen und Reise-/Terminstatus.
- **Regulatory Delta Inbox:** Zeigt Änderungen eines Regelwerks und die konkret betroffenen Controls, Policies, Evidence und Services.
- **ISMS Year in Review:** Automatisch erzeugte Geschichte der wichtigsten Entscheidungen, Risikoveränderungen, Investitionen und erreichten Ziele.
- **Process Twin:** Zeigt für jeden ISMS-Prozess Durchlaufzeit, Blocker, Qualität, Kosten und Automatisierungspotenzial.
- **Service Conversion Moment:** Erkennt wiederkehrende manuelle Belastung und schlägt transparent einen passenden Managed Service mit erwartetem Nutzen vor.

32. Quellen- und Versionsregister

Die folgenden Primärquellen begründen den methodischen Bezugsrahmen; verbindlich sind jeweils die offiziell bezogenen Originaltexte und kundenspezifisch anwendbaren Fassungen.

43. ISO: ISO/IEC 27001:2022 - Information security management systems - Requirements. <https://www.iso.org/standard/27001>
44. ISO: ISO/IEC 27001:2022/Amd 1:2024 - Climate action changes. <https://www.iso.org/standard/88435.html>
45. ISO: ISO/IEC 27000:2026 - ISMS overview. <https://www.iso.org/standard/27000>
46. BSI: BSI-Standards und IT-Grundschutz-Methodik; aktuelle offizielle Fassungen über das IT-Grundschutz-Portal. <https://www.bsi.bund.de/grundschutz>
47. BSI: IT-Grundschutz Online-Kurs, insbesondere Strukturanalyse, Schutzbedarf, Modellierung und IT-Grundschutz-Check. <https://www.bsi.bund.de/grundschutzkurs>
48. Europäische Union: Richtlinie (EU) 2022/2555 (NIS2), insbesondere Governance und Cybersecurity-Risikomanagementmaßnahmen. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
49. Europäische Union: Verordnung (EU) 2022/2554 (DORA), insbesondere Governance und IKT-Risikomanagementrahmen. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj>
50. Europäische Union: Delegierte Verordnung (EU) 2024/1774 zu DORA-Risikomanagementtools, -methoden, -prozessen und -richtlinien. https://eur-lex.europa.eu/eli/reg_del/2024/1774/oj

Versionsregel: Das Produkt speichert niemals nur einen Framework-Namen. Es speichert konkrete Version, Amendment/Delegated Act, Gültigkeit, Bezugsquelle, Lizenzstatus und kundenspezifische Anwendbarkeit.

33. Abhängigkeiten und nächste Dokumente

- Dokument 09 definiert Reifegrad, Risiko-, Threat- und Control-Intelligence einschließlich Berechnungs- und Vertrauenslogik.
- Dokument 10 übersetzt die Prozesse in Decision Center, KPIs, Zielrouten und Simulationen.
- Dokument 11 präzisiert Aufgaben, Zusammenarbeit, Freigaben und Kommunikation.
- Dokument 12 definiert Reporting, PDF und PowerPoint aus den Prozessdaten.
- Dokument 13 bis 16 operationalisieren Managed Services, Servicekatalog, Beraterbetrieb und Kunden-Onboarding.
- Dokument 17 bis 19 definieren Integrationen, technische Architektur, Sicherheit, Datenschutz und Rechte.
- Dokument 20A bis 20C definieren KI-Funktionen, Agentenfirma und Claude-Code-Betriebssystem.

34. Änderungsprotokoll

Version	Datum	Änderung	Autor/Verantwortung
1.0	21.07.2026	Erstfassung des kanonischen ISMS-Prozessmodells mit 18 Kernprozessen, Zuständen, Managed-Service-Grenzen und Akzeptanzkriterien.	Produktkonzeption